情報処理安全確保支援士試験　科目A-2　中分類23 情報セキュリティの脅威　#04

ネットワーク・DNS・DoSの攻撃

送信元を偽る、名前解決をだます、量で押しつぶす。パケットの向きで攻撃を読み解く

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案、CISA、RFC、CERT/CC、JPCERT/CC など）を書いた。過去問は IPA 公開の午前 II 。例のアドレスや会社は Claude が作った

全体像 シラバス案 中分類23 小分類2「信頼を悪用した攻撃」「サービスの妨害を狙った攻撃」

1 なりすましと信頼の悪用
IP・ARP スプーフィング・第三者中継・フィッシング・スミッシング・標的型・水飲み場型・SEO ポイズニング

2 DNS への攻撃
キャッシュポイズニング・カミンスキー攻撃・ドメイン名ハイジャック・オープンリゾルバ

3 サービス妨害
SYN フラッド・バックスキャッタ・Smurf・HTTP フラッド・Slow HTTP・マルチベクトル・リフレクション（DNS・NTP）

過去の午前 II での出方（平成31〜令和7年度）

テーマ	出た回
Smurf 攻撃はどれか	H31春・R3春・R4秋・R6秋
未使用アドレスへの SYN/ACK	R4秋・R6春・R7秋
カミンスキー・キャッシュポイズニング	H31春・R5春・R7春
リフレクション（NTP・DRDoS・サービス）	R3春・R6秋・R7春
マルチベクトル型 DDoS	R1秋

> DoS は**毎年のように出る**。同じ問題の選択肢の順番を入れ替えて再出題されることが多い。

出典：IPA「支援士試験 シラバス（案）Ver.0.1」中分類23 小分類2／IPA 午前 II 各回（このPDFの問題演習を参照）

第1章

なりすましと信頼の悪用

「送り主」「宛先」「見慣れたサイト」を偽る。

IP スプーフィングと ARP スプーフィング

IP スプーフィング：送信元アドレスを偽る

プロトコル	偽装の通りやすさ
UDP・ICMP	応答を待たないので、そのまま通る → 反射・増幅に使われる
TCP	3ウェイハンドシェイクが完了しない → SYN フラッドに使われる

対策：境界で送信元を検査（イングレスフィルタリング、BCP 38）。外から来たのに**送信元が内部**のパケットは捨てる。

ARP スプーフィング（ARP ポイズニング）



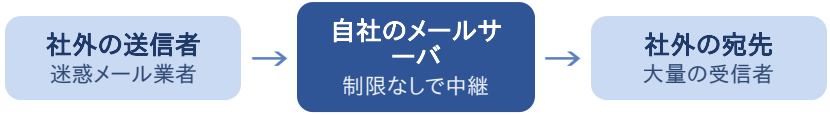
LAN の中だけで起きる。ゲートウェイになりすますと**外へ出る通信をすべて盗聴・改ざん**（中間者攻撃、#02）。

対策：スイッチの DHCP スヌーピング＋DAI（ダイナミック ARP インスペクション）、静的 ARP。

出典：RFC 2827（BCP 38）Network Ingress Filtering／Cisco「Configuring Dynamic ARP Inspection」／IPA「支援士試験 シラバス（案）」中分類25「DHCP スヌーピング」

第三者中継とフィッシングの仲間

第三者中継（オープンリレー）



踏み台にされ、IP が**ブラックリスト入り** → 自社の正規メールも届かない。

対策：中継する送信元を自組織に限る、SMTP-AUTH、OP25B（#14）。

攻撃	入口	特徴
フィッシング	メール	本物そっくりの偽サイトで資格情報を入力させる
スミッシング	SMS	不在通知などを装う。偽アプリを入れさせる手口も
標的型攻撃	業務に見せたメール	事前に偵察。長期に潜伏（APT）
水飲み場型	標的がよく見る正規サイト	標的の IP のときだけ攻撃コード
SEO ポイズニング	検索結果	話題の言葉で罠のサイトを上位に

出典：IPA「支援士試験 シラバス（案）」用語例「第三者中継（オープンリレー）」「フィッシング（スミッシング）」「標的型攻撃」「SEO ポイズニング」

第2章

DNS への攻撃

正しいドメイン名を入れても、偽のサイトへ連れて行かれる。

DNS キャッシュポイズニング：答えより先に偽の答えを届ける

① 利用者
www.bank.example の IP は？

→

② キャッシュ DNS
権威サーバに問い合わせ中

→

③ 権威 DNS
正しい答え（遅れて届く）

攻撃者
偽の答えを大量に送る

→

キャッシュに偽の IP
利用者全員が偽サイトへ

偽の答えが受け入れられる条件	対策
DNS ヘッダの ID（16 ビット）が一致	**ID をランダムに**
宛先ポート（＝問い合わせの送信元ポート）が一致	**ポートをランダムに**
正しい答えより先に届く	**—**
内容の正しさを確かめていない	**DNSSEC で署名（#16）**

H31春 問11：正解は「ID をランダムに変更」。「送信元ポート番号を **53 に固定**」は逆効果のひっかけ。

出典：RFC 5452 Measures for Making DNS More Resilient against Forged Answers／IPA 午前 II 平成31年度春期 問11

カミンスキー攻撃：何度でも試せるようにした

	従来の攻撃	カミンスキー攻撃（2008）
問い合わせる名前	www.bank.example	a1.bank.example、a2…（存在しない）
失敗したら	**正しい答えがキャッシュされ TTL の間は再挑戦できない**	次の名前ですぐ再挑戦
偽の答えの中身	その名前の IP	bank.example 全体の権威サーバを偽サーバに

当たる確率の目安

ID だけ：2^{16} ≒ 6.5万通り　→　ID×ポート：
約 6.5万 × 約6万 ≒ 約40億通り

R7春 問4（R5春 問5 と同じ）：正解は「問合せ時の**送信元ポート番号をランダム化**」。

誤りの選択肢	本当は何の対策か
計2台の冗長構成	**過負荷・故障**
SPF でレコードを認証	**メールの送信元（#14）**
プレースホルダ	**SQL インジェクション（#03）**

出典：CERT/CC VU#800113（2008）／RFC 5452／IPA 午前 II 令和7年度春期 問4・令和5年度春期 問5。確率の数字は Claude の概算

ドメイン名ハイジャックとオープンリゾルバ

ドメイン名ハイジャック

キャッシュをだますのではなく、**登録情報や権威 DNS そのもの**を書き換える。だれが引いても偽サーバに着く。

入口	対策
レジストラのアカウントの乗っ取り	MFA、レジストリロック
権威 DNS への侵入	登録情報・NS の監視
残ったサブドメインの CNAME（テイクオーバー）	使わない DNS レコードを消す

オープンリゾルバ

だれからの再帰問い合わせにも答えるキャッシュ DNS サーバ。

DNS アンプ攻撃の踏み台
送信元を偽った問い合わせに大きな応答を返す

キャッシュポイズニングの的
外部から問い合わせを起こさせやすい

対策：再帰問い合わせを自組織の利用者に限る。権威 DNS とキャッシュ DNS を分ける。

出典：JPCERT/CC「オープンリゾルバに関する注意喚起」／IPA「支援士試験 シラバス（案）」中分類23 用語例

第3章

サービス妨害（DoS・DDoS）

何を使い切らせるのか（回線・接続・処理）で分ける。

SYN フラッドとバックスキャッタ

3ウェイハンドシェイクを途中で止める

正常	SYN フラッド
① SYN →	① SYN →（送信元は偽）×大量
② ← SYN/ACK	② ← SYN/ACK（偽の送信元へ）
③ ACK →（接続完了）	**③ 来ない → 待ち行列が満杯**

SYN cookie：SYN では待ち行列を使わず、情報を SYN/ACK のシーケンス番号に埋め込む。正しい ACK が来たら接続（RFC 4987）。

R7秋 問7（R4秋・R6春 と同じ）

```
送信元 A : 80/tcp  →  未使用アドレス
種類 SYN/ACK × 大量
```

1. A は SYN/ACK（**応答**）を返している側
2. 宛先が未使用 → だれかが送信元を偽って A に SYN を送った
3. だから **A を攻撃先とするサービス妨害**（ア）

未使用のアドレス（ダークネット）に届くこうした応答を**バックスキャッタ**という。NICTER などが観測に使う。

出典：RFC 4987 TCP SYN Flooding Attacks and Common Mitigations／IPA 午前 II 令和7年度秋期 問7／NICT「NICTER 観測レポート」

Smurf 攻撃:ブロードキャストで増やす

攻撃者
ICMP エコー要求
送信元=標的・宛先=ブロードキャスト

→

踏み台のネットワーク
全機器がエコー応答を返す

→

標的
大量の ICMP エコー応答

R6秋 問6 の選択肢	正体
ICMP エコー要求・送信元=標的・宛先=ブロードキャスト	**Smurf(正解)**
受信可能範囲を超える大きなパケット	**Ping of Death など**
偽の送信元の SYN を大量、ACK を返さない	**SYN フラッド**
ボットネットで大量のなりすましメール	**メール爆弾**

H31春・R3春 の版では「ICMP の**応答**パケットを大量に発生させ…攻撃対象に送られる」、R4秋 では「偽装した ICMP の**要求**パケットを送って、大量の**応答**パケットが攻撃対象に」が正解。

対策:ルータでダイレクテッドブロードキャストを転送しない。

出典:IPA 午前 II 令和6年度秋期 問6・平成31年度春期 問6・令和3年度春期 問4・令和4年度秋期 問4

アプリケーション層の DoS：HTTP フラッドと Slow HTTP

	HTTP フラッド	Slow HTTP
量	大量の GET・POST	少ない
使い切らせるもの	処理能力（アプリ・DB）	同時接続数
手口	重い検索などを連打	ヘッダ・本文を数秒おきに少しずつ
気付き方	要求数の急増	量は普段どおりで接続が埋まる
対策	レート制限・Bot 判定・WAF・CDN	受信タイムアウト短縮・IP ごとの同時接続数制限

Slowloris の送り方（イメージ）

```
GET / HTTP/1.1
Host: www.example.jp
（10秒待つ）
X-a: 1
（10秒待つ）
X-b: 2    …空行を送らず終わらせない
```

> **R7春 問1：**「多数の HTTP リクエストを長期間掛けて送信し続け、セッションを占有」は DRDoS ではなく Slow HTTP。

出典：Apache HTTP Server ドキュメント「Security Tips」Denial of Service (DoS) attacks・mod_reqtimeout／IPA 午前 II 令和7年度春期 問1

リフレクション（DRDoS）と増幅率

攻撃者
小さな要求 × 多数
送信元＝標的

→

第三者のサーバ
DNS・NTP・Memcached…

→

標的
大きな応答が集中

プロトコル	増幅率（CISA）	使われる要求
DNS	28〜54	ANY 型、署名付き応答
NTP	556.9	monlist（最大600件の一覧）
SSDP	30.8	M-SEARCH
SNMPv2	6.3	GetBulk
Memcached	10,000〜51,000	stats など（UDP 11211）

R3春 問1：悪用されやすいのは「**DNS, Memcached, NTP**」。DKIM・DNSSEC・SPF や IPsec・TLS は違う。

R6秋 問4：NTP サーバは**踏み台**。「送信元を偽って、レスポンスが大きくなるリクエストを送る」が正解。「NTP サーバに echo request」は ICMP なので誤り。

出典：CISA「Alert TA14-017A UDP-Based Amplification Attacks」（増幅率の表）／IPA 午前 II 令和3年度春期 問1・令和6年度秋期 問4

DDoS とマルチベクトル型

R1秋 問13:マルチベクトル型はどれか

選択肢	攻撃の種類
DNS リフレクタで DNS を止める	1種類
SYN Flood と HTTP POST Flood を同時に	2種類(L4+L7)
IoT 機器から UDP Flood	1種類(台数は多い)
FW の送信順序を操作して枯渇	1種類

「多数の機器から」は DDoS の条件で、**マルチベクトル**の条件ではない。

DDoS への備え(詳しくは #13)

CDN・Anycast
大容量の回線と多数の拠点で受け止めて分散

スクラビングセンター
通信を引き込み、攻撃の通信だけ取り除いて返す

レート制限・Bot 対策
L7 の攻撃を見分けて絞る

送信元検証(BCP 38)
自分のネットワークから偽装パケットを出さない

出典:IPA 午前 II 令和元年度秋期 問13／IPA「支援士試験 シラバス(案)」中分類25「DDoS 対策(CDN, スクラビングセンター, Anycast, レート制限)」

過去問の問われ方のまとめ

パケットの向きを読む：応答（SYN/ACK・エコー応答）を出している側は**被害者**か**踏み台**。送信元を偽った要求が先にある。

DNS は「ランダム化」：ID と送信元ポート番号をランダムに。固定するのは逆。根本的には DNSSEC。

リフレクションの条件：UDP・送信元を偽れる・応答が大きい。DNS・NTP・Memcached。

名前	一言で
Smurf	ICMP ＋ ブロードキャスト
SYN フラッド	ACK を返さず待たせる
DRDoS	第三者のサーバに反射させる
Slow HTTP	ゆっくり送って接続を占有
マルチベクトル	種類の違う攻撃を組み合わせる
カミンスキー	存在しない名前で何度でも毒入れ

出典：IPA 午前 II 平成31〜令和7年度（このPDFの問題演習）